

D3-FI 全面安全复检报告(v2)

针对当前代码的二次全量白盒审计 · 3 组对抗性 agent · 线上系统实测试验证

项目:D3-FI-UI(Supabase Edge Functions/Deno + BSC 合约 + React) · 分支: `main`
重大变更:认证已由 Privy 迁移为 Reown AppKit + SIWE(EIP-4361);两阶段 UD3 结算;sD3→UD3 重命名;Cloudflare Pages 自动部署
日期:2026-07-17 · 阶段:未上线 · 结算币:测试/水龙头币(fake USDT)

最终判定:CONDITIONAL — 核心资金安全经实测试验证达标;本次新增发现为中/低危 + 运维项

SIWE

认证已重写并经线上验证

全部

原有资金防护经重构后仍完好

20/20

新表+原表 RLS 锁定(实测 anon 0 授权)

0

新增可直接盗资金的严重漏洞

一、结论摘要

自上次修复后,代码发生重大演进(认证从 Privy 迁移到 SIWE、两阶段 UD3 结算、UD3 重命名、Cloudflare 自动部署)。本次对当前代码做了全量二次审计,并对线上运行系统做了实测试验证。

核心结论:资金安全姿态强,且经实测试验证。新的 SIWE 认证设计良好(登录时以钱包签名证明所有权,下游只信任会话令牌主体,不再信任任何可伪造请求头);上次修复的全部防护(原子借贷记、闪兑五重护栏、质押原子扣减、充值幂等、限额熔断、价格护栏、奖励幂等、推荐完整性)在重构后**全部保持完好**,未发现新的资金盗取/超发路径。

本次新增发现集中在迁移编号冲突、CI/权限、DoS 节流、约束补齐等中低危与运维项。综合判定维持 **CONDITIONAL**:测试期(水龙头币)安全;承载真实资金前完成第五节部署清单即可。

二、经实测试验证的核心防护(CLOSED)

域	结论	证据(当前代码 / 线上实测)
SIWE 认证	强 · 已验证	nonce 单次+原子消费+5min TTL;签名恢复==声明地址;域名服务端白名单(不信任请求 Host);HS256 常量时间校验、无 alg 混淆;线上:登录 200、无令牌资金路由 401 失败关闭
钱包身份	已关闭	全部资金路由由身份取自会话令牌 <code>sub</code> ; <code>X-Wallet-Address</code> 仅当与之匹配才接受;A 会话无法冒充 B
原子借贷记	重构后仍完好	<code>pending_d3_yield</code> / <code>ud3_balance</code> 全部经原子 RPC;两阶段结算未引入读改写
闪兑	已关闭	请求时原子扣减+在途唯一+失败回补+仅未广播才退款+≥12 确认
质押/充值	已关闭	质押原子扣减+订单去重;充值入口守卫+链上金额校验+原子跃迁幂等
限额/熔断/价格	已关闭	扣减前 <code>assertWithdrawAllowed</code> (单笔/日/时/偿付率);价格失效即拒付
数据库锁定	已验证	14 原表 + <code>siwe_nonces</code> /告警/风控/审批 等新表全部 RLS;线上实测 anon 表授权 = 0
后台/推荐	已关闭	admin RLS 递归修复正确;maker-checker+不可变审计;推荐防自荐/环路/双归属

三、本次新增 / 遗留发现

ID	发现	严重度	状态	修复
R-1	迁移编号冲突:两个 <code>038_*</code> 、两个 <code>042_*</code> , <code>db push</code> 以 version 为主键,安全关键迁移 (<code>038_risk_controls</code> / <code>042_siwe_auth</code>)可能被静默跳过或阻断部署	High	待修	重命名为唯一编号(如 044/045)后再 push;线上对象已存在,仅修文件与迁移记录
R-2	水龙头币("USDT" 可任意 mint)作为结算资产写入主网生产构建 (<code>VITE_BSC_USDT_ADDRESS</code> + <code>VITE_USDT_IS_FAUCET=true</code> , chain 56)	High(须核实)	测试期有意	此为你既定"测试期 fake 币"策略;上线前钉真实 USDT、移除 faucet 标志;确认测试期未开启真实价值提现

R-3	跨权限审批: /approvals/:id/approve 仅校验 subsidies.write ,却可执行 security.unpause / risk_limits.update → 无 security.write 的管理员可批准解除熔断/放宽限额	Med	待修	审批路由按审批 action 校验对应权限(security.* 需 security.write)
R-4	陈旧 deploy-pages.yml 仍在 push 时发布第二个(Privy 时代)公开源,可能是过期登录面	Med	待修	删除该 workflow 或确认该源已下线,且不在 SIWE_ALLOWED_DOMAINS
R-5	/auth/nonce 与 /auth/verify 无 apikey、无限流 → nonce 表无限增长 + 签名恢复 CPU DoS	Low-Med	待修	按 IP/地址限流 + nonce 过期清理任务
R-6	043 新增 partner_accounts.pending_ud3 缺 CHECK ≥ 0 (其余余额列均有)	Low-Med	待修	补非负约束(防御性,当前代码不会致负)
R-7	两阶段结算: settle_pending_ud3 出错被吞但 ledger 仍标记 settled=true → 奖励滞留 pending_ud3 (用户少记,金库安全)	Low-Med	待修	仅在 settle 成功后再标记 settled
R-8	会话令牌 7 天且无吊销/jti/轮换 → 泄露后 7 天有效	Low	待修	加 jti+吊销表或缩短 TTL+轮换
R-9	.env.example 未列 SIWE_SESSION_SECRET / SIWE_ALLOWED_DOMAINS / TREASURY_CRON_SECRET (线上已设,仅文档缺失,易致新环境误配)	Low	待修	补入 .env.example(占位)
R-10	ReferralRegistry 三角色(含 UPGRADER/REBIND)在 backfill 期由单一热 EOA 持有	Low-Med	链上核实	核实已转多签并 renounce 热 EOA
R-11	信息项: upsertReferralFromChain 缺自身 user!==upline 自荐守卫(依赖合约);死代码 credit_ud3_balance (041)、privy.ts 认证导出未引用	Info	清理	加防御性自荐检查;删除死代码

四、线上系统实测验证结果

```
登录      POST /union/auth/nonce      -> 200  {"nonce":"..."}      (SIWE 正常)
资金路由 POST /treasury/partner/sd3-stake -> 401  Session token required (失败关闭,非 503)
匿名直连 anon key -> d3_price_settings 读/改 -> 401 permission denied      (RLS 生效)
匿名直连 anon key -> multisig_signatures 伪造 -> 401 permission denied      (RLS 生效)
线上库    siwe_nonces RLS=on, anon 授权=0 ; 全 schema anon 表授权 = 0
线上库    5 个原子余额 RPC 均 security definer ; 6/6 新表 RLS 开启
边缘函数  treasury /health -> 200 (钱包基础设施、金库、闪兑均 configured)
密钥      SIWE_SESSION_SECRET / SIWE_ALLOWED_DOMAINS / TREASURY_CRON_SECRET 均已部署
```

说明:审计 agent 曾据 .env.example 未列 SIWE 变量而推断"生产未配置导致认证宕机";经上述线上实测证伪——密钥已设、登录与失败关闭均正常。这正是对线上验证的价值。

五、部署 / 运维检查清单(承载真实资金前)

- R-1:重命名重复迁移编号(038/042),再 supabase db push 对齐迁移记录
- R-2:上线前 BSC_USDT_CONTRACT / VITE_BSC_USDT_ADDRESS 钉真实 USDT、移除 faucet 标志与 ALLOW_MAINNET_FAUCET_TOKEN ;确认测试期无真实价值提现
- R-3:审批路由按 action 校验权限(security.* → security.write)
- R-4:删除或下线陈旧 deploy-pages.yml 第二源
- R-5:给 /auth/* 加限流 + nonce 清理;R-6:补 pending_ud3 ≥ 0 ;R-7:settle 成功才标记;R-8:会话吊销/短 TTL;R-9:补 .env.example
- R-10:ReferralRegistry 角色转多签 + renounce 热 EOA(链上核实)
- 凭证隔离:Turnkey root quorum≥2,金库/cosigner 密钥不与边缘环境共存
- 部署边缘函数 npm run supabase:deploy (本次已部署 6 个函数);执行 npm run turnkey:policies
- 配置告警推送 SECURITY_* 密钥;确认 d3-security-scan cron(每 5 分钟,已注册)

已完成 / 已验证

- ✓ SIWE 认证(线上登录/失败关闭正常)· 全库 RLS + anon 授权清零(实测)
- ✓ 原子借贷记 / 闪兑五重护栏 / 质押原子 / 充值幂等 / 限额熔断 / 价格护栏(重构后仍完好)
- ✓ 后台 maker-checker + 不可变审计 · 监控引擎 + 熔断开关 + 安全中心页 · 部署前 preflight

六、监控与守护(现状)

监控引擎(偿付率击穿自动暂停闪兑、闪兑量激增、价格异常、充值异常、待审批、熔断提醒)、Telegram/Slack 推送、admin「安全中心」熔断页、每 5 分钟扫描 cron 均已就位;暂停可单人即时,恢复须双人审批。事件响应见 `INCIDENT_RUNBOOK.md`,清单见 `SECURITY_CHECKLIST.md`。

本报告基于当前 `main` 分支代码 + 线上数据库/边缘函数实测 + 3 组对抗性 agent 复检生成。"已验证"结论均有 file:line 证据或线上响应支撑。上一版报告(Privy 时代)已按要求删除并由本报告替代。生成于 2026-07-17。